Roles, Permissions and Audit: Reference

Access is part of inventory control. Every account should have the smallest role that lets the person do their job, and every material change should be attributable.

Roles

- Administrators manage products, stock, master data, and other accounts, including deletion where the application allows it.
- Operators handle day-to-day receiving, dispatch, and physical counts. They cannot remove products.
- A role is a boundary, not a promotion path. Change it only with an approved request.

Enforcement

- Permissions are checked in the server action or route that performs the work, not only by hiding interface controls.
- Read-only masters and reference documents still require a signed-in session.
- Input is validated on the server; filters and identifiers never become raw database commands.

Sessions and passwords

- Sessions use an httpOnly cookie. Only a hash of the session token is stored, and sessions expire.
- Password changes require the current password and revoke other sessions for that account.
- Sign out on shared devices. Never send credentials through chat or email.

Audit trail

- Sign-in, sign-out, failed sign-in, password changes, product changes, receipts, dispatches, and counts are recorded.
- Entries keep the actor, action, entity, IP address where available, and timestamp.
- Audit records are append-only from the application. Define a retention period before pruning them.

Routine checks

- Review inactive accounts and remove access promptly when someone leaves.
- Investigate repeated failed sign-ins and unusual after-hours activity.
- Back up the database and test restoration; an audit trail is only useful if the data survives.